

**School of Computer Science and Engineering**

**Faculty of Engineering**

**The University of New South Wales**

**PathTriage: Exploitability-Ranked IAM Attack-Path Discovery and  
Defender-Output Synthesis for AWS and Azure**

by

**Hyeon (Tessa) Moon**

z5660470

Submitted: July 2026

Supervisor: Lachlan Jones

# Preamble

## Abstract

This work investigates the construction of an exploitability-ranked catalogue of IAM privilege-escalation paths in cloud environments, and the synthesis of defender output — detection queries and remediation policies — for each ranked path. The work covers both AWS and Azure, and introduces AI agents (Bedrock Agents, Azure OpenAI Assistants) as first-class entry nodes in the IAM attack graph, bridging MITRE ATLAS and MITRE ATT&CK for Cloud. This report acts as a progress update for the first phase of a two-term Master’s project.

## Acknowledgements

This work has been supported by the academic staff of UNSW’s School of Computer Science and Engineering. Supervision and direction have been provided by Lachlan Jones.

# **Table of Figures**

# List of Figures

# Definitions

**IAM** Identity and Access Management. The cloud-provider subsystem that governs which principals may perform which actions on which resources.

**Attack path** A sequence of permissions and resources by which a low-privileged principal can reach an effectively higher-privileged state.

**PoC** Proof of Concept. A working implementation that demonstrates an attack primitive end-to-end against a controlled lab.

**IMDS** Instance Metadata Service. The local HTTP endpoint (169.254.169.254) on AWS EC2 instances that returns instance and role information, including temporary credentials.

**MITRE ATT&CK for Cloud** The adversary-tactics-and-techniques framework extended to IaaS environments.

**MITRE ATLAS** The adversarial-threat framework for AI and machine learning systems.

# Contents

|                                                 |          |
|-------------------------------------------------|----------|
| <b>Preamble</b>                                 | <b>1</b> |
| <b>Table of Figures</b>                         | <b>2</b> |
| <b>Definitions</b>                              | <b>4</b> |
| <b>1 Introduction</b>                           | <b>6</b> |
| <b>2 Previous Work</b>                          | <b>7</b> |
| 2.1 IAM Analysis Tools . . . . .                | 7        |
| 2.2 Cloud Attack Path Research . . . . .        | 7        |
| 2.3 AI Agent Security and MITRE ATLAS . . . . . | 7        |
| <b>3 Current Progress</b>                       | <b>8</b> |
| 3.1 Lab Architecture . . . . .                  | 8        |
| 3.2 Verified Attack Paths . . . . .             | 8        |
| 3.3 PathTriage Prototype . . . . .              | 8        |
| 3.4 Engineering Decision Log . . . . .          | 8        |
| <b>4 Future Work</b>                            | <b>9</b> |
| 4.1 Remaining T2 Catalogue . . . . .            | 9        |
| 4.2 Term 3 Scope . . . . .                      | 9        |
| 4.3 Risks and Mitigations . . . . .             | 9        |

# Chapter 1

## Introduction

The rise of cloud computing has shifted the security perimeter from the network to the identity layer. Misconfigured IAM is now a leading cause of cloud breaches [1].

Existing IAM analysis tools largely operate at the per-permission level: they audit whether a principal holds a given action on a given resource. They miss a distinct class of vulnerability — the *combination* of permissions that forms a viable escalation path. PathTriage addresses this gap by modelling cloud IAM as a directed graph, discovering reachable escalation paths, ranking them by a defended exploitability metric, and emitting both detection rules and mitigation policies for each ranked path.

## **Chapter 2**

# **Previous Work**

### **2.1 IAM Analysis Tools**

### **2.2 Cloud Attack Path Research**

### **2.3 AI Agent Security and MITRE ATLAS**



## **Chapter 3**

# **Current Progress**

### **3.1 Lab Architecture**

### **3.2 Verified Attack Paths**

### **3.3 PathTriage Prototype**

### **3.4 Engineering Decision Log**

## **Chapter 4**

# **Future Work**

### **4.1 Remaining T2 Catalogue**

### **4.2 Term 3 Scope**

### **4.3 Risks and Mitigations**

# Bibliography

- [1] IBM Security, “Cost of a Data Breach Report 2025,” 2025, placeholder — replace with actual citation. [Online]. Available: <https://www.ibm.com/reports/data-breach>